BLO VAULT — Information Security Policy

Version: 1.1
Effective: November 2026
Owner: Chan Hong (BLO VAULT operator)
Classification: Internal / Partner disclosure (Plaid)

1. Purpose and scope

This Information Security Policy (“Policy”) defines how BLO VAULT identifies, mitigates, and monitors information security risks for the BLO VAULT mobile application, its supporting backend services used as a Plaid proxy, and related operational processes.

Scope includes: iOS, Android, and macOS client builds distributed to end users; Supabase-backed Edge Functions and data stores used for Plaid token proxying, authentication, and encrypted backup storage; development, build, and release workflows; subprocessors listed in the public Privacy Policy.

Out of scope: Security programs of financial institutions, Plaid, Inc., Apple, Google, or other third parties (governed by their own policies).

This Policy is operationalized through documented procedures referenced below, tooling (CI/CD, monitoring), and periodic review.

2. Roles and responsibilities

Role	Responsibility
Operator / Developer (Chan Hong)	Owns this Policy; implements controls in application and backend configuration; responds to incidents and vulnerability reports; approves subprocessors for production use.
End users	Protect device passcodes/biometrics; use in-app security features (e.g., session lock, Panic Delete) as appropriate.

3. Information security program (continuous improvement)

BLO VAULT maintains an information security program that is reviewed at least annually and updated for changes in product architecture, applicable law (including U.S. state privacy laws and CCPA/CPRA), and partner requirements.

The program includes:

- Risk identification: Review of architecture (on-device financial data, encrypted token storage, network boundaries), threat scenarios (token exposure, unauthorized access, key compromise), and dependency/supply-chain risk.
- Risk mitigation: Technical and procedural controls in Sections 5–12.
- Risk monitoring: Automated testing in CI/CD, crash/diagnostic telemetry where enabled (Sentry), and manual review of critical changes.

4. Risk management methodology

1. Identify — Map data flows (Plaid → App → local encrypted store; Apple FinanceKit → App → local encrypted store; App ↔ Supabase proxy; encrypted backup to iCloud, or to Supabase as fallback; optional Sentry; subscriptions via Apple/Google/RevenueCat). Document assets and subprocessors.
2. Mitigate — Apply controls proportional to risk (encryption, access control, least privilege on backend, secure development practices).
3. Monitor — Run static analysis and tests in pipeline; track crashes and regressions; reassess after incidents or major releases.

5. Data classification and handling

Category	Examples	Handling
Highly sensitive	Plaid-linked and Apple Card / Apple Cash (FinanceKit) transaction and balance data used in-app	Stored only on the user device in AES-256 encrypted storage (SQLCipher). FinanceKit data is read on the device and never sent to BLO VAULT servers. No readable copy of the ledger is stored on BLO VAULT servers.
Highly sensitive	Encrypted vault backups	Encrypted on the device (AES-256-GCM) with a key derived from a random recovery key before upload. Kept in the user's private iCloud container by default; uploaded to Supabase as ciphertext only if iCloud cannot be used and the user has confirmed the recovery code. BLO VAULT cannot decrypt either copy.
Sensitive	Encrypted Plaid access tokens, opaque link ids (Plaid item/account ids), Apple user identifier and optional email or Hide My Email relay address (Supabase Auth), operational usage counts, plan and beta-access records, optional feedback. No readable account names or balances.	Encrypted at application layer before storage; access limited to authenticated user sessions and Row Level Security (RLS) on Supabase.
Operational	Build secrets, API keys (developer environment)	Stored outside public repositories; not committed to version control.

Category	Examples	Handling
Diagnostic	Crash reports (if Sentry enabled)	Client configured to reduce identifiable user fields; governed by Sentry's terms and project settings.

Biometric data: Processed by the OS only; BLO VAULT does not store biometric templates.
SSN / government ID (OCR): Not retained when excluded at capture/processing stages per product design.

6. Access control

- Sign-in: On iOS, Sign in with Apple is the primary sign-in (same account across devices and reinstalls); Apple passwords are never received. On other platforms, a pseudonymous Supabase user is used. The session is kept in the device Keychain and is never included in backups.
- Consumer access to the App: Face ID / Touch ID or device PIN/passcode via platform APIs before access to financial data; session timeout (15 minutes of inactivity) requiring re-authentication.
- Backend / Supabase: Access via short-lived JWTs tied to user sessions; RLS restricts data to the owning user. Developer access to Supabase dashboard follows vendor best practices (e.g., SSO where configured).
- Principle of least privilege: No standing employee access to end-user financial ledger content on servers (by architecture: raw transaction history is not centralized on BLO VAULT servers).

7. Cryptography and transmission security

- Data at rest (device): AES-256 (SQLCipher); key material protected via iOS Keychain / Android Keystore (or equivalent secure storage).
- Data in transit: HTTPS (TLS) for all application traffic to BLO VAULT-controlled and configured services, using the platform's standard certificate validation. Certificate pinning is not used.
- Backups: Vault backups are encrypted on the device with AES-256-GCM using a key derived from a random recovery key. The recovery key is also kept in iCloud Keychain (end-to-end encrypted by Apple) for iCloud backups; the server backup does not contain the recovery key.
- Tokens: Plaid access tokens are encrypted before persistence in Supabase.
- On-device assistant: The optional assistant runs an on-device language model through the Cactus SDK; financial ledger content is not sent to cloud LLM providers for inference.

8. Secure development and change management

- Secure SDLC practices aligned with OWASP Mobile Top 10 awareness; security-minded design for authentication, storage, and Plaid integration.
- Automated checks: GitHub Actions CI runs static analysis (flutter analyze), automated tests, and dependency vulnerability scanning on security-relevant paths.
- Code review: Security-sensitive changes reviewed before merge where practicable for solo-operator workflow.
- Planned hardening (roadmap): Additional controls (e.g., jailbreak/root detection, tamper detection, expanded memory hygiene) are tracked against the main product

roadmap and rolled in as implemented.

9. Vulnerability and patch management

- Dependency and supply chain: Monitor advisories; upgrade packages per severity-based targets (e.g., Critical ~24h, High ~72h, Medium ~7 days) where feasible for a small team.
- Disclosure intake: Security issues may be reported to info@blovault.com (temporary); acknowledgment targeted within 48 hours; status updates within 7 days when practical; remediation timelines aligned with severity.
- Formal security@ address and published VDP page are planned when @blovault.com mail is available (see repository FUTURE.md).

10. Incident response

Documented response paths include:

Scenario	Initial steps
Suspected Plaid token exposure	Suspend or limit affected Edge Function paths if needed; invoke Plaid /item/remove for impacted items; notify affected users as required; document for GLBA-aligned financial privacy obligations where applicable.
Encryption key compromise	Guide users through Panic Delete / re-enrollment; rotate server-side secrets and keys per runbooks.
Unauthorized access / abuse	Suspend affected services as needed; preserve logs per retention; root-cause analysis; user notification per legal requirements (e.g., breach timelines under applicable law).

Incidents are logged; post-incident review updates controls and this Policy as needed.

11. Vendor and third-party management

Subprocessors, as listed in Section 4 of the Privacy Policy, are Plaid, Supabase, RevenueCat, Apple / Google (in-app purchases, platform services, optional OS speech processing), Sentry (optional, only if a DSN is configured), and Google ML Kit (on-device text recognition); some features also request non-identifying reference or market data over HTTPS. They are selected for fit with BLO VAULT’s architecture. Contracts or standard terms are accepted per vendor. Consumer-facing disclosures appear in the Privacy Policy (privacy-policy.md). Changes to material subprocessors trigger Privacy Policy updates.

12. Data retention and secure disposal

Aligned with the Data Retention and Disposal practices supplied with the Plaid production package:

Data type	Retention (summary)	Disposal method
Financial transaction data (on-device)	Until the user deletes it	Immediate local wipe via Panic Delete, Delete account & data, or Delete account permanently; uninstalling also removes it
Plaid connections / access tokens	Removed at Plaid when the 14-day free trial, subscription, or beta access ends; after Panic Delete or Delete account & data, by the last day of the current calendar month; after Delete account permanently, by the last day of the current calendar month	Plaid /item/remove + Supabase deletion
iCloud backup copies and synced recovery key	Current copy plus one previous copy	Deleted immediately by Panic Delete and account deletion; the user may also remove them via iCloud settings
Server backup (fallback)	One copy per account	Deleted immediately by Delete account permanently; by the last day of the current month for Panic Delete / Delete account & data
Sign in with Apple data (Apple user identifier, email or relay address)	While the account exists	Deleted with the account; the App's Apple sign-in token is revoked where Apple allows
Feedback records and attachments	While needed for support, unless deleted earlier	Deleted on account deletion
Biometric data	Not stored by BLO VAULT	N/A (OS-only)
Complimentary (permanent) beta access	Connections removed after 90 days without opening the App	Plaid /item/remove; the user may link again

Details follow Section 9 of the Privacy Policy, which governs if the two differ.

13. Monitoring and logging

- Application stability: Optional Sentry for crashes/performance, only if a DSN is configured; configuration minimizes PII in events.
- Backend: Supabase and Edge Function logs used for abuse detection, rate limiting (e.g., requests per user), and incident investigation, within retention limits of the platform.

14. Policy review and distribution

- Review frequency: At least annually, and after material incidents or architecture changes.
- Distribution: Published in the blovault-web repository for partner and auditor reference; summaries reflected in consumer Privacy Policy where appropriate.
- Versioning: Version and effective date updated at top of document when revised.

15. Contact

Information security / privacy (temporary): info@blovault.com

This document supports Plaid and similar partner security questionnaires. It does not constitute legal advice. Align runtime controls and automation with stated procedures before representing full operational maturity.